

Anonymous Tracing: A Dangerous Oxymoron

A Risk Analysis for Non-Specialists

Slides by Andrea Vitaletti based on  <https://risques-tracage.fr/>

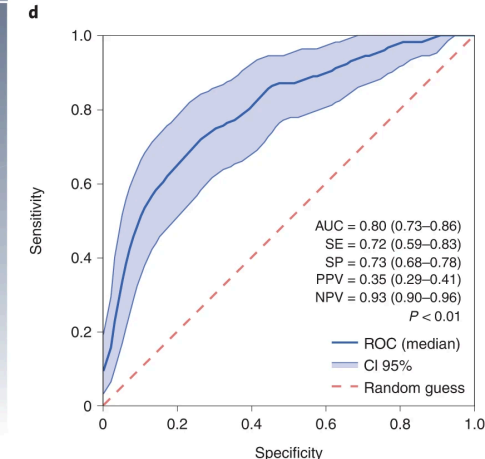
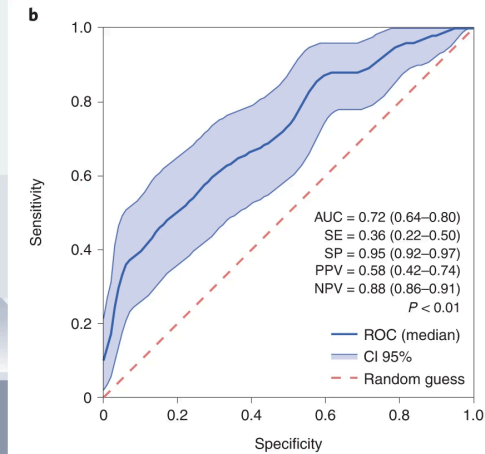
Context: COVID-19 Contact Tracing Apps

🔑 Studies suggest the employment of Contact Tracing Apps for epidemic control of COVID-19

E.g. Quantifying SARS-CoV-2 transmission suggests epidemic control with digital contact tracing

🌐 <https://bdi-pathogens.shinyapps.io/covid-19-transmission-routes/>

🌐 <https://doi.org/10.1038/s41587-022-01350-x>
risques-tracage.fr



Context: COVID-19 Contact Tracing Apps

- Governments planned mobile apps to **alert people exposed to COVID-19 patients**
- Guiding promise: *privacy-respecting* design using Bluetooth pseudonyms
- Active debate between researchers on **centralised vs. decentralised** approaches

Goal

Clarify what a tracking app **could and could not** guarantee — regardless of its technical implementation

Summary of Claims vs. Reality

Claim	Reality
No patient-name database	TRUE
Data is anonymous	FALSE
Impossible to find out who infected whom	FALSE
Impossible to know if a specific person is sick	FALSE
Impossible to trigger a false alarm	FALSE
Bluetooth is not a security issue	FALSE
The system makes large-scale snooping impossible	FALSE

How the App Works

- Each phone **generates a random pseudonym** every ~5 minutes
- Phones in proximity **exchange pseudonyms via Bluetooth** and record the time
- Data stored locally for **14 days**
- If **Alice tests positive** → app alerts all contacts (e.g. Bob) who received her pseudonyms

HOW PRIVACY-FIRST CONTACT TRACING WORKS



How Bob is informed

⚙ The Models

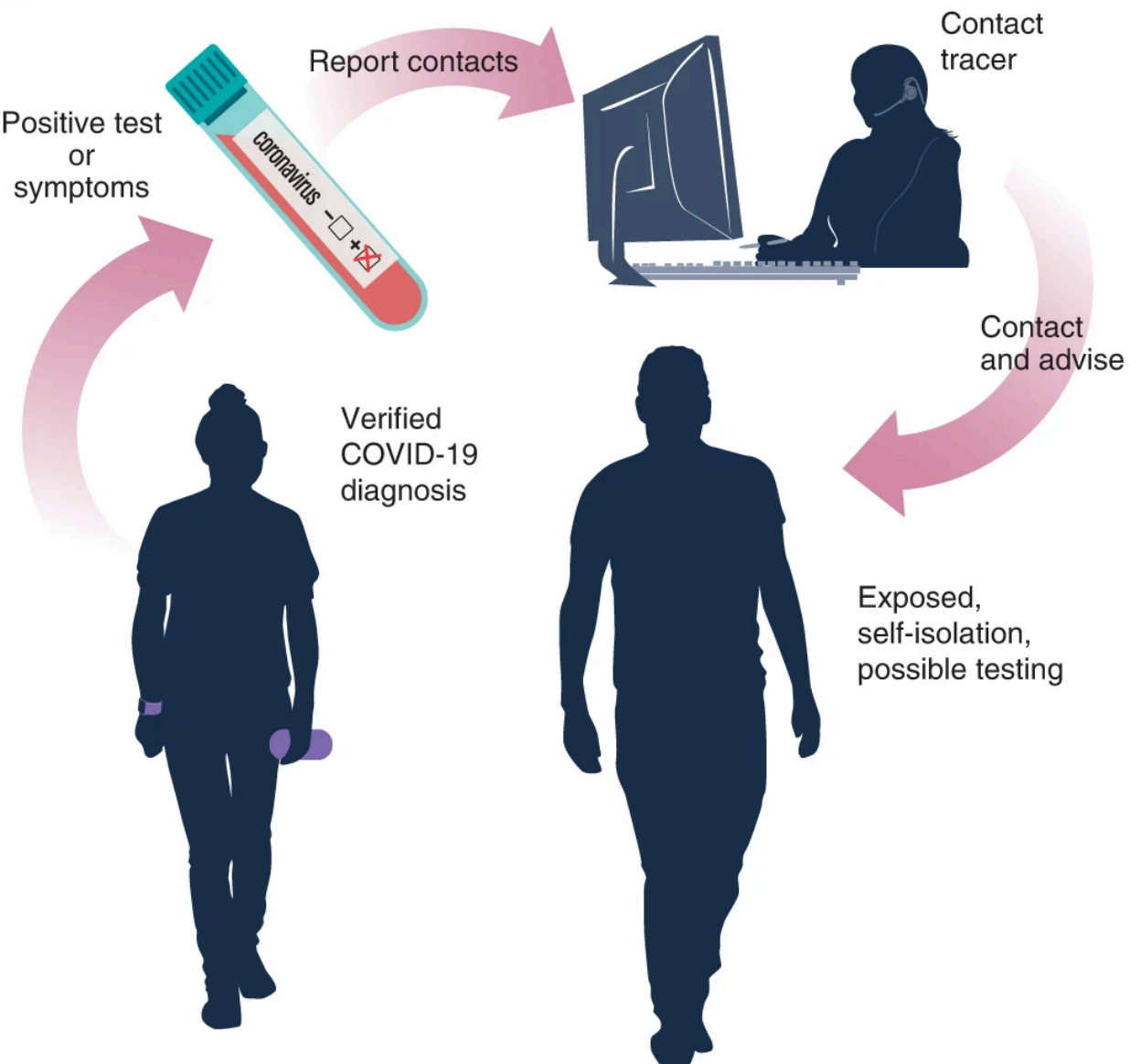
- **Decentralised** (DP3T, Apple/Google): **Alice's pseudonyms are published publicly** (e.g. p2p, bulletin board); Bob checks locally.
- **Centralised** (ROBERT): **Alice's contacts pseudonym (BoB included) are sent to a server**; The server informs BoB.

HOW PRIVACY-FIRST CONTACT TRACING WORKS

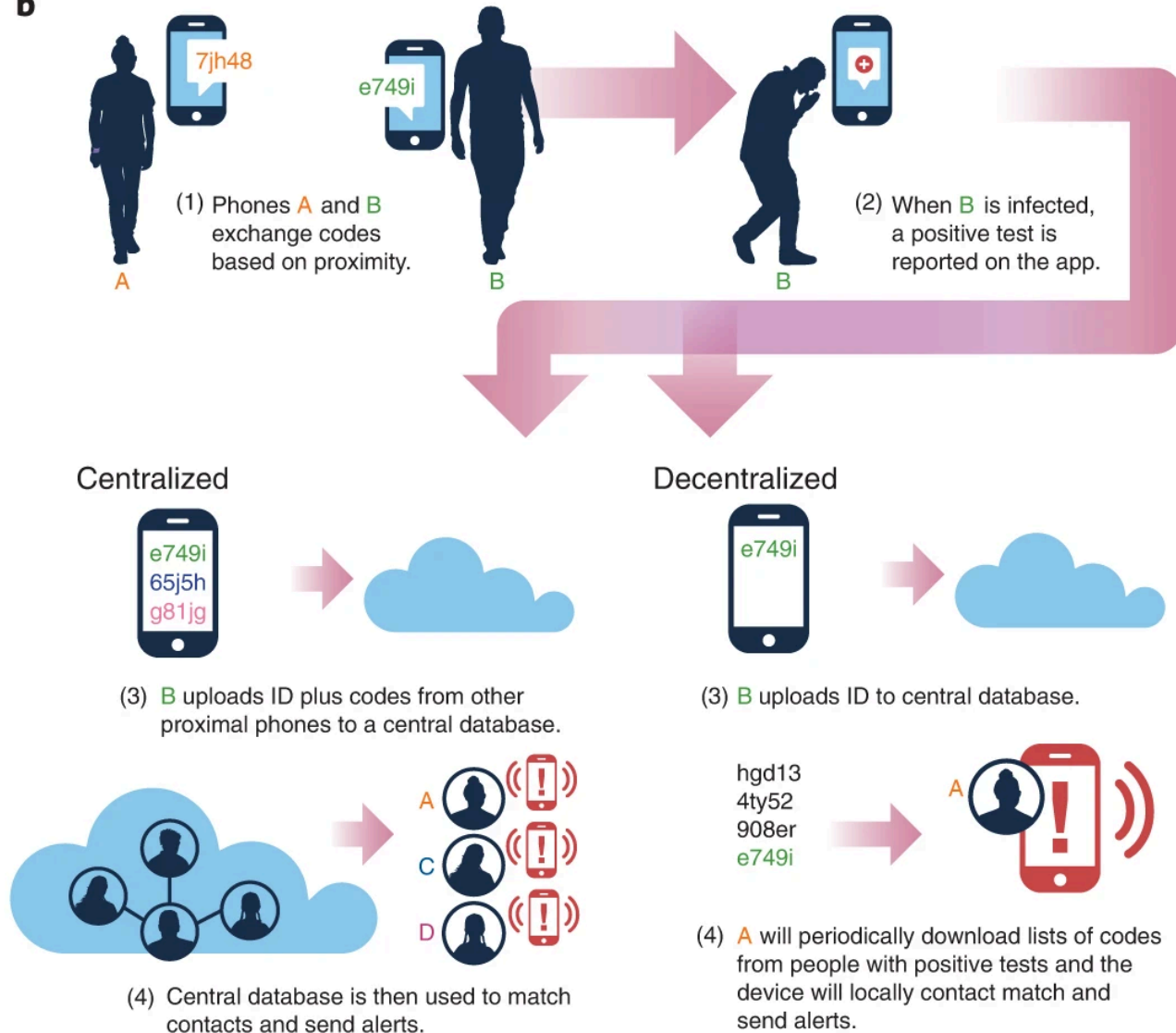


Anonymous Tracing: A Dangerous Oxymoron

a



b



Data is NOT Anonymous

- Records are **pseudonymised**, not anonymous — a critical distinction under the [GDPR\(Article 4\(5\)\)](#):
- De-anonymisation possible via: **Bluetooth antenna, IP address, or cross-referencing contacts**

Type	Example
Nominative	Mr. Bloggs is sick
Pseudonymous	Pseudonym 439Hxs is sick
Truly anonymous	There are 50,437 cases

How to Find Out Who Infected You

Even without technical skills, users can infer identities:

Scenario: The Sole Suspect — Mr. Smith never leaves home except to shop at the neighbourhood grocery. He receives a notification. Only one person can be responsible: the grocer.

Scenario: Information Crossing — Mrs. Jones receives a notification and chats with neighbours (notif.) and colleagues ($\neg$ notif.). She narrows the source to Mr. Attrisk on the 3rd floor and posts her suspicion on social networks.

These scenarios require **no hacking skills** — only social deduction.

How to Find Out Who Infected You

Even without technical skills, users can infer identities:

Scenario: Are my neighbours sick? — Mr. Hipokondriac would like to know if his neighbours are sick. He finds his old telephone in a cupboard, installs the TraceVIRUS app, and leaves it in his mailbox at the bottom of his building. All of the neighbours pass by each time they return home, and the phone will receive a notification if one of them is sick.

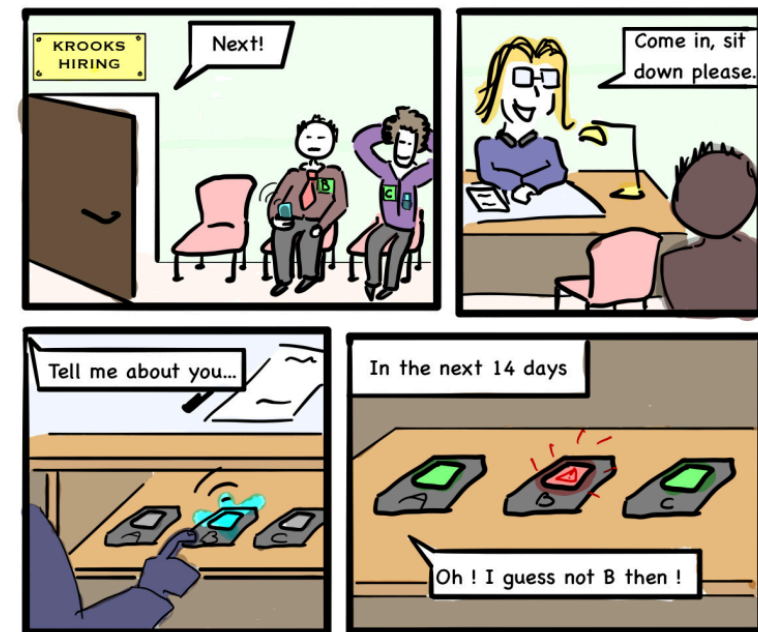
These scenarios require **no hacking skills** — only social deduction.

How do you know if a specific person is sick?

Any tracking system that notifies contacts **can be used to monitor a specific person**:

1. Use a **dedicated phone** registered only with the target
2. Keep the phone near the target during an interaction
3. Receive an alert if the target later tests positive

Scenario: The Job Interview — The KROOKS company uses a dedicated phone only during the interview. They will be notified if the candidate later tests positive — giving them discriminatory medical information.



False Alarms Are Easy to Trigger

Scenario: The Anti-System Activist — Mr. Spart ties his phone to his dog and lets it run in the park all day. He then tests positive, and all dog walkers receive a COVID notification.

Scenario: The Pupil Bart Symptomson — Bart borrows a sick person's phone, passes it around his classroom and staffroom. The sick person tests positive → the whole school is forced to close.

Impact

False alarms can **target individuals** (athletes, job candidates, negotiators) or **disable entire systems** at scale.

Bluetooth Itself Is a Security Risk

- Bluetooth was **not designed to test physical proximity** (e.g. detects through walls)
- Activating Bluetooth opens **known security vulnerabilities** (e.g. Blueborne, 2017)
- Bluetooth signals can be **captured from over 1 km** with a directional antenna

Scenario: Burglary — Ms. Beagle scans for Bluetooth signals before entering Uncle Duck's house.
No signal = house is empty.

Scenario: Mall Surveillance — A shopping centre uses a Bluetooth antenna at the entrance to detect which customers are running the tracing app.

WhisperPair

- **Bluetooth hijacking** Google Fast Pair not correctly implemented → attacker can forcefully pair with a vulnerable bluetooth accessory /record audio, pump up volume).
- **Location tracking** Using Google's Find Hub Network

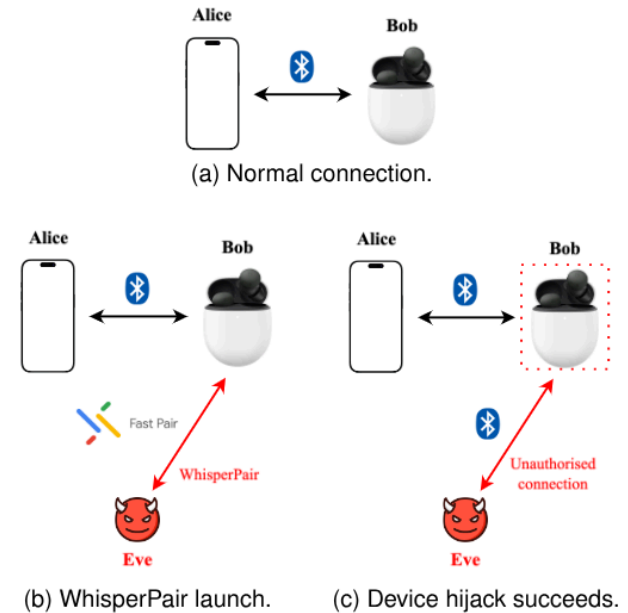


Figure 3. The WhisperPair hijack. (a) A benign Bluetooth session: Alice's phone streams audio to her earbuds. (b) Eve exploits Fast Pair, launching WhisperPair to initiate an unsolicited pairing with the same earbuds. (c) The attack succeeds: Eve completes an unauthorised session and takes control of the earbuds.

Towards Large-Scale Snooping

Even without official access, third parties can build shadow registries:

- **By users:** A companion app (GeoTraceVIRUS) pairs GPS coordinates with Bluetooth pseudonyms, revealing where sick patients were.
- **By data companies:** Retailers already use in-store Bluetooth tracking; linking it with tracing pseudonyms creates a private list of sick customers.
- **By cyber criminals:** Malware can blackmail users who declare a positive test, or sell "infect your neighbour" services.

In Decentralised solution, ids are public ← easier re-identification

Towards Large-Scale Snooping

Key Insight

Most attacks exploit **features** of these systems, not bugs — they cannot be fixed by better cryptography alone.

Conclusions

- These risks are **inherent in how contact tracing works**, not just implementation details
- Cryptography can only address a **limited subset** of these threats
- The scenarios presented are **known, plausible, and easy to execute**

The Core Trade-off

The benefits of digital tracing remain **highly uncertain**, while the privacy and security harms are **concrete and foreseeable**. Political choices — not technology — must weigh these.

"Information technology must be at the service of every citizen ... it should infringe neither on human identity, nor on human rights, nor on privacy, nor individual or public freedoms."

— French "Computing and Freedoms" Act, 1978

"Asking people to choose between privacy and health is, in fact, the very root of the problem. Because this is a false choice. We can and should enjoy both privacy and health. We can choose to protect our health and stop the coronavirus epidemic not by instituting totalitarian surveillance regimes, but rather by empowering citizens." [source](#)

Life & Arts + Add to myFT

Yuval Noah Harari: the world after coronavirus | Free to read

This storm will pass. But the choices we make now could change our lives for years to come

Anonymous Tracing: A Dangerous Oxymoron

Rashida Jones Chris O'Dowd

Common People

Discussion

- Should society deploy systems with **known, unavoidable privacy risks** for epidemiological benefits that remain uncertain?
- Who bears responsibility when tracing is **misused by employers, insurers, or criminals**?
- How do we balance **collective health protection** with **individual rights** in a surveillance-capable society?